



Politécnico
Internacional

FUNDAMENTOS EN CIBERSEGURIDAD

**“Solo hay dos tipos de empresas:
las que han sido hackeadas y las que
lo serán.”**

— Robert Mueller, exdirector del FBI

- ☐ Riesgos
- ☐ Vulnerabilidades
- ☐ Análisis de riesgos
- ☐ Modelos Análisis de riesgos
- ☐ Metodologías Cualitativas y Cuantitativas
- ☐ ISO 31000
- ☐ Identificación de Amenazas
- ☐ Análisis e Identificación de Vulnerabilidades
- ☐ Materialización de Amenazas
- ☐ Análisis Remoto Caja Blanca
- ☐ Análisis Remoto Caja Negra
- ☐ NIST SP 800-30
- ☐ Metodología MAGERIT

Riesgos

En seguridad informática, un riesgo es la probabilidad de que una amenaza explote una vulnerabilidad en un sistema o activo, causando un impacto negativo. Es una combinación de tres factores clave:

Riesgo = Amenaza + Vulnerabilidad + Impacto

El riesgo no es solo la existencia de amenazas, sino la posibilidad real de que estas generen un daño si las condiciones son propicias (por ejemplo, fallas en controles de seguridad).

Elementos involucrados:

Activo: Información, sistemas, hardware, software, etc.

Vulnerabilidad: Fallo o debilidad en un sistema.

Amenaza: Actor o evento potencialmente dañino.

Impacto: Consecuencia financiera, operativa o legal.



Ejemplo Riesgo

Una empresa de comercio electrónico almacena datos de tarjetas de crédito en una base de datos que no está cifrada (vulnerabilidad). Si un atacante externo con conocimientos de SQL Injection (amenaza) logra explotar esa vulnerabilidad y extrae los datos, el riesgo se materializa. El impacto podría incluir sanciones legales por incumplimiento de PCI DSS, pérdida de reputación y costos de respuesta a incidentes.



Vulnerabilidad en Seguridad Informática

Una vulnerabilidad es una debilidad o fallo en el diseño, la implementación, la configuración o la operación de un sistema de información que puede ser explotada por una amenaza para comprometer la confidencialidad, integridad o disponibilidad de los activos.

Las vulnerabilidades pueden estar presentes en:

Software (errores de codificación, desbordamientos de búfer)

Hardware (fallos de firmware)

Configuraciones inseguras (puertos abiertos innecesarios, contraseñas por defecto)

Procesos organizacionales (falta de políticas de acceso, errores humanos)



Ejemplo: Vulnerabilidad en Seguridad Informática

Una aplicación web permite que los usuarios ingresen texto en un formulario de búsqueda sin aplicar filtros ni validaciones. Esta omisión genera una vulnerabilidad de tipo **XSS (Cross-Site Scripting)**. Un atacante puede insertar un **script malicioso** que se ejecuta en el navegador de otro usuario cuando este visita la página, robando su **cookie de sesión**. Esto pone en riesgo la integridad de las cuentas de usuario y puede derivar en una escalada de privilegios.



Análisis de Riesgos

El análisis de riesgos en ciberseguridad es el proceso sistemático de identificar, evaluar y priorizar los riesgos asociados con los activos digitales de una organización, con el objetivo de tomar decisiones informadas sobre las medidas de seguridad que se deben implementar. Incluye:

Identificación de activos: Datos, servidores, aplicaciones, redes.

Identificación de amenazas: Actores maliciosos, malware, errores humanos.

Identificación de vulnerabilidades: Fallos técnicos o procedimentales.

Evaluación de impacto y probabilidad: Consecuencias y frecuencia esperada.

Determinación del nivel de riesgo: Mediante matrices de riesgo u otras metodologías (por ejemplo, ISO/IEC 27005, NIST SP 800-30).

El análisis puede ser:

Cualitativo: Se mide en niveles (alto, medio, bajo).

Cuantitativo: Se estiman pérdidas económicas (por ejemplo, valor en dólares).



Ejemplo: Análisis de Riesgos

Una universidad realiza un análisis de riesgos sobre su sistema de gestión académica (**activos**). Detecta que el servidor de base de datos está expuesto a Internet sin segmentación de red (**vulnerabilidad**), y que recientemente se han detectado ataques de ransomware dirigidos al sector educativo (**amenaza**).

Probabilidad: Alta (por exposición directa a Internet y ataques frecuentes).

Impacto: Crítico (pérdida de notas, datos personales, parálisis operativa).

Riesgo evaluado: Alto

Medidas sugeridas: Segmentar la red, aplicar firewall de aplicación web (WAF), hacer copias de seguridad offline, restringir accesos, actualizar parches.



Modelos de Relaciones en Análisis de Riesgos

Los modelos de relaciones en análisis de riesgos son representaciones estructuradas que permiten visualizar e interconectar los elementos clave del riesgo: activos, amenazas, vulnerabilidades, impactos, controles y riesgos. Estos modelos ayudan a comprender cómo interactúan estos elementos para priorizar decisiones de mitigación.

Se utilizan principalmente para:

- Identificar cadenas de eventos.**
- Representar relaciones causa-efecto.**
- Mapear la exposición de activos.**
- Apoyar el análisis cuantitativo o cualitativo.**



Tipos de Modelos

Modelo Activo-Amenaza-Vulnerabilidad-Riesgo-Impacto (AAVRI): Relaciona cómo una amenaza explota una vulnerabilidad sobre un activo, generando un riesgo y su impacto.

Modelo CORAS (basado en UML): Usa diagramas gráficos para representar amenazas, activos, vulnerabilidades y escenarios de ataque. Muy usado en entornos formales.

Modelo OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation): Relaciona amenazas, vulnerabilidades y activos críticos con un enfoque organizacional.

Modelo de Árbol de Riesgo (Risk Tree): Representa visualmente posibles combinaciones de fallas o eventos que conducen a un incidente de seguridad.



Metodologías Cualitativas y Cuantitativas en análisis de riesgos

Metodologías Cualitativas y Cuantitativas

En ciberseguridad, las **metodologías cualitativas y cuantitativas** son enfoques utilizados para **evaluar y medir el nivel de riesgo** al que están expuestos los activos de una organización. Ambas metodologías se aplican durante el análisis de riesgos, pero **difieren en su nivel de precisión, datos requeridos y complejidad**.



Metodologías Cualitativas y Cuantitativas en análisis de riesgos

Metodología Cualitativas

Enfoque: Descriptivo y subjetivo.

Evaluación: Se basa en la experiencia, juicio experto o escalas (por ejemplo: bajo, medio, alto).

Herramientas: Matriz de riesgo, entrevistas, cuestionarios, lluvia de ideas.

Ventaja: Fácil de aplicar, rápida, no requiere datos exactos.

Desventaja: Menor precisión y repetibilidad.



Metodologías Cualitativas y Cuantitativas en análisis de riesgos

Ejemplo: Metodología Cualitativas

Un administrador de TI evalúa que el servidor de correo de la empresa:

- Tiene múltiples intentos de acceso no autorizado (**amenaza**).
- No cuenta con autenticación multifactor (**vulnerabilidad**).
- Podría comprometer la información sensible de empleados (**impacto**).

Se clasifica el riesgo como:

Probabilidad: Alta

Impacto: Alto → Riesgo: Crítico.

- Se usa una matriz de riesgo para priorizar la implementación de controles.



Metodologías Cualitativas y Cuantitativas en análisis de riesgos

Metodología Cuantitativa

Enfoque: Numérico y objetivo.

Evaluación: Usa datos financieros, estadísticos y probabilísticos.

Fórmula clave:

Riesgo = Valor del activo × Probabilidad de ocurrencia × Impacto económico esperado

Herramientas: Análisis Monte Carlo, ALE (Annualized Loss Expectancy), SLE (Single Loss Expectancy), tasas de ocurrencia.



Metodologías Cualitativas y Cuantitativas en análisis de riesgos

Ejemplo: Metodología Cuantitativa

Una empresa calcula el riesgo de un ataque de ransomware en su servidor contable.

Activo: Servidor contable (valorado en \$50.000 USD).

Probabilidad anual: 10% (basada en historial y contexto sectorial).

Impacto por evento (SLE): \$30.000 USD

Pérdida anual esperada (ALE):

$ALE = SLE \times ARO$ (Annual Rate of Occurrence)

$ALE = 30.000 \times 0.10 = \3.000 USD

La organización decide invertir en respaldo offline y segmentación, porque el costo de mitigación es menor al impacto esperado.



ISO 31000

La **ISO 31000** es una norma internacional publicada por la Organización Internacional de Normalización (ISO) que proporciona principios, un marco y un proceso para gestionar riesgos de manera efectiva. No está enfocada únicamente en ciberseguridad, sino que es aplicable a cualquier tipo de organización y contexto, incluyendo seguridad de la información, proyectos, operaciones, salud y seguridad, etc.



ISO 31000

Principios de la gestión del riesgo:

- Integrada
- Estructurada y completa
- Personalizada
- Inclusiva
- Dinámica
- Basada en la mejor información disponible
- Considera factores humanos y culturales
- Mejora continua



ISO 31000

Marco de trabajo:

- Liderazgo y compromiso
- Integración con los procesos organizacionales
- Diseño del marco
- Implementación
- Evaluación
- Mejora continua



ISO 31000

Proceso de gestión del riesgo:

- Comunicación y consulta
- Establecimiento del contexto
- Identificación del riesgo
- Análisis del riesgo
- Evaluación del riesgo
- Tratamiento del riesgo
- Monitoreo y revisión
- Registro e informe

Esta norma es complementaria a marcos específicos como ISO/IEC 27005 (riesgos en seguridad de la información) y puede integrarse con otras como ISO 9001, ISO 22301, etc.



IDENTIFICACION DE AMENAZAS

La identificación de amenazas es la etapa del análisis de riesgos en la que se reconocen y documentan los agentes, eventos o condiciones que tienen el potencial de causar daños a los activos de información de una organización. Las amenazas pueden ser **intencionales** (por ejemplo, ciberataques) o no **intencionales** (como errores humanos o fallas técnicas), y pueden explotar vulnerabilidades existentes en sistemas o procesos.

Esta etapa es crítica para anticipar posibles incidentes y preparar estrategias de mitigación.



CLASIFICACIÓN DE AMENAZAS

Amenazas humanas intencionales: Hackers, insiders maliciosos, delincuencia organizada.

Amenazas humanas no intencionales: Errores de configuración, borrado accidental, clics en phishing.

Amenazas tecnológicas: Malware, ransomware, ataques DDoS, explotación de 0-days.

Amenazas físicas o ambientales: Incendios, inundaciones, cortes eléctricos, terremotos.

Amenazas organizacionales: Procesos mal definidos, falta de políticas de seguridad.



Análisis e Identificación de Vulnerabilidades

Análisis e identificación de vulnerabilidades

El análisis e identificación de vulnerabilidades es el proceso mediante el cual una organización detecta, clasifica y evalúa las debilidades que existen en sus activos tecnológicos, humanos o de procesos, y que podrían ser explotadas por una amenaza para comprometer la confidencialidad, integridad o disponibilidad de la información.

Este proceso forma parte integral del análisis de riesgos y permite anticipar incidentes, aplicar controles adecuados y priorizar recursos.



Análisis e Identificación de Vulnerabilidades

Fuentes de vulnerabilidades

Software: Código inseguro, versiones desactualizadas, bibliotecas vulnerables.

Hardware: Firmware con errores, dispositivos sin parches.

Configuración: Puertos abiertos innecesarios, servicios habilitados por defecto.

Red: Ausencia de segmentación, protocolos inseguros.

Usuarios: Contraseñas débiles, falta de formación, ingeniería social.

Procesos: Políticas inexistentes o no aplicadas, errores en la gestión del cambio.



Herramientas de Gestión de vulnerabilidades

Escaneo automático de vulnerabilidades

Ejemplos: Nessus, OpenVAS, Qualys, Nexpose.

Pruebas manuales o auditorías técnicas

Revisiones de configuración, análisis de código fuente.

Evaluaciones de cumplimiento

Basadas en normas como ISO/IEC 27001, NIST, CIS Controls.

Penetration testing (pentesting)

Simulación controlada de ataques reales para encontrar brechas.

Revisión de bases de datos de vulnerabilidades

CVE (Common Vulnerabilities and Exposures), NVD, OWASP Top 10.



Materialización de Amenazas

La materialización de una amenaza ocurre cuando una amenaza identificada logra explotar una o más vulnerabilidades, generando un incidente de seguridad real que afecta la confidencialidad, integridad o disponibilidad de un activo.

Es decir, es el paso de lo potencial a lo real: la amenaza se convierte en un ataque efectivo o un evento dañino. Esta etapa es crítica porque transforma un riesgo teórico en un impacto medible.

Relación con el análisis de riesgos:

Amenaza: Existe la posibilidad de ataque.

Vulnerabilidad: Hay debilidades que permiten el ataque.

Riesgo: Evaluación de la probabilidad y el impacto.

Materialización: El ataque o evento ocurre y causa daño.



Materialización de Amenazas

Una organización usa un sistema ERP expuesto a Internet. Se había identificado como amenaza un posible ataque de fuerza bruta, y como vulnerabilidad el uso de contraseñas débiles sin límite de intentos fallidos. Un atacante automatiza un script y logra acceder a una cuenta administrativa utilizando una contraseña predecible ("admin123"). Este acceso permite modificar datos contables y extraer información confidencial.

Aquí, la amenaza (ataque de fuerza bruta) se ha materializado, explotando una vulnerabilidad concreta (contraseñas débiles y sin políticas de bloqueo).

Impacto:

Daño reputacional.

Alteración de información financiera.

Posible sanción por incumplimiento de normativas.



Análisis Remoto Caja Blanca

El análisis remoto de caja blanca (también llamado white-box testing remoto) es una técnica de evaluación de seguridad en la que el auditor o analista tiene acceso completo a la información interna del sistema (código fuente, arquitectura, configuraciones, credenciales, etc.) y realiza la prueba desde un entorno distinto al sistema objetivo, es decir, de forma remota. Este enfoque permite realizar una evaluación detallada y controlada sobre cómo podría un atacante interno (o externo con información privilegiada) explotar debilidades, pero sin necesidad de estar físicamente en la red objetivo.

Características principales:

Acceso completo: Se conocen detalles internos del sistema (código, APIs, estructuras de datos).

Pruebas profundas: Permite detectar vulnerabilidades lógicas, errores de diseño, malas prácticas de codificación y configuraciones incorrectas.

Enfoque remoto: Se ejecutan las pruebas a través de redes (VPN, SSH, túneles), sin presencia física.

Alta cobertura: Es más exhaustivo que el análisis de caja negra o gris. Enfocado en el lado del desarrollador o del administrador.



Análisis Remoto Caja Negra

El análisis de caja negra es una técnica de evaluación de seguridad en la que el analista no tiene conocimiento previo del funcionamiento interno del sistema, su código fuente, ni configuraciones. Se enfoca exclusivamente en lo que un atacante externo podría ver o acceder desde fuera, simulando un ataque real. Este tipo de análisis parte desde el mismo punto de vista de un hacker: sin credenciales, sin acceso privilegiado, y con el objetivo de descubrir vulnerabilidades explotables desde el exterior.

Características clave:

- Sin acceso al **código fuente** ni a la arquitectura.
- Se exploran únicamente las **interfaces expuestas** (sitios web, APIs, puertos abiertos, etc.).
- Permite detectar **errores de configuración, malas prácticas de despliegue, vulnerabilidades en servicios expuestos**, etc.
- Alta similitud con escenarios **reales de ataque**.
- Es útil para identificar el "**nivel de exposición real**" de una organización frente a amenazas externas.



NIST SP 800-30

La NIST SP 800-30 Rev. 1 (National Institute of Standards and Technology Special Publication) es una guía técnica oficial del gobierno de EE.UU. que proporciona una metodología estructurada para realizar análisis de riesgos en sistemas de tecnología de la información. Forma parte del marco de ciberseguridad del NIST y se centra en **identificar, evaluar y gestionar los riesgos que afectan la seguridad de la información.**

Esta metodología se aplica ampliamente en entornos públicos y privados por su enfoque claro, sistemático y adaptable..



ETAPAS METODOLOGIA NIST SP 800-30

Preparación para la evaluación del riesgo: Definir propósito, alcance, suposiciones, limitaciones, fuentes de datos y participantes.

Realización de la evaluación del riesgo: Identificación de amenazas: Qué puede afectar negativamente (malware, ataques, errores humanos).

Identificación de vulnerabilidades: Debilidades que pueden ser explotadas.

Determinación de la probabilidad: Qué tan probable es que una amenaza explote una vulnerabilidad.



ETAPAS METODOLOGIA NIST SP 800-30

Determinación del impacto: Consecuencias operativas, financieras o legales.

Determinación del nivel de riesgo: Combinación de probabilidad e impacto.

Comunicación de resultados: Elaboración de informes con resultados técnicos y recomendaciones ejecutivas.

Mantener la evaluación del riesgo: Reevaluar periódicamente o ante cambios en tecnología, procesos o amenazas.



METODOLOGIA MAGERIT

MAGERIT (**Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información**) es un marco metodológico desarrollado por el Consejo Superior de Administración Electrónica de España, cuya versión 2 se publicó en 2006. Su objetivo es analizar y gestionar los riesgos que amenazan los sistemas de información, ayudando a identificar activos, valorar amenazas y vulnerabilidades, estimar riesgos y definir salvaguardas adecuadas.

Características clave de la versión 2:

- Establece un modelo estructurado de activos, amenazas y salvaguardas.
- Permite clasificar los activos según su criticidad.
- Proporciona una metodología modular y escalable, adaptable a distintos niveles de profundidad.
- Incorpora catálogos de amenazas y salvaguardas, así como mapas de riesgos.
- Se apoya en herramientas como PILAR para automatizar el análisis.



EJEMPLO: METODOLOGIA MAGERIT

Una universidad pública en Colombia implementa MAGERIT versión 2 para evaluar su plataforma de educación virtual. En el proceso:

Identifica activos como la base de datos de estudiantes, servidores de autenticación y sistema de gestión académica.

Clasifica las amenazas como fallos de hardware, ciberataques, y errores de configuración.

Calcula el impacto potencial de cada amenaza sobre los activos mediante matrices de valoración.

Define contramedidas como copias de seguridad automatizadas, firewalls de nueva generación, y formación al personal.

Genera un informe detallado de los riesgos, proponiendo planes de acción priorizados por criticidad.



CONCLUSIONES